

[Logo: Hackles]

Concepts Lab

Trust your hackles. Pause · Check · Tell.

FIELD COPY

1



Lock It

PASSWORDS AND ACCOUNTS

2



Spot It

SCAMS AND FAKES

3



Share Smart

PRIVACY

4



Safe People

WHO TO TRUST

5



Kind and Well

KINDNESS AND BALANCE

6



Fix It

TELL, REPAIR, RECOVER

PLATE I. The six strands, hand-in-inked, in the order the lessons take them.

A free kit by Competence Collective · competencecollective.org · quillsup.org

© 2026 Competence Collective. Lesson text and teaching materials: CC BY-NC 4.0 (free to print, share and adapt for non-commercial use with credit). The Hackles name, logos, characters and artwork are not covered by that license: print and share them unaltered for classroom and family use; any other use needs written permission. [VERIFY with counsel]



OCTOBER 2026

Hackles • Cybersecurity Concepts Lab for Teachers

Demo 6: Two Locks Are Better Than One (The Vault Door Role-Play)

Trust your hackles. Pause • Check • Tell

A free kit by Competence Collective • competencecollective.org • quillsup.org

© 2026 Competence Collective. Lesson text and teaching materials: CC BY-NC 4.0 (free to print, share and adapt for non-commercial use with credit). The Hackles name, logos, characters and artwork are not covered by that license: print and share them unaltered for classroom and family use; any other use needs written permission. [VERIFY with counsel] **No student accounts, no student data collected, ever.**

Status: DRAFT for teacher, counselor and legal review. Items marked [VERIFY] need checking against a primary source before publication.

AT A GLANCE

Big idea	A stolen password alone should not be enough. A second proof (something you have or are) stops most takeovers, and the best second proofs (passkeys and security keys) cannot be handed to a fake website.
Grade bands	K-2 (the two-key treehouse), 3-5 (two-lock chest), 6-8 (full Vault Door), 9-12 (full + passkey challenge-response and recovery risk)
CSTA-style concepts	Networks and the Internet (cybersecurity: authentication, tradeoffs between usability and security), Impacts of Computing (codes: see Concepts Lab Index, Part 4 [VERIFIED 2026-10-05])
Time	15-minute and 45-minute versions
Cost and tech	Index cards, envelopes, two cheap padlocks (optional), a rubber stamp or hole punch. No devices.
Teachers do it first	Yes. Part A about 20 minutes.

MAKE IT STICK

Try This Now (60 seconds, no prep): Ask a neighbor: "Name one thing you know, one thing you have, and one thing you are (like a fingerprint that unlocks a phone)." Which two together make a stronger lock than a password alone? (Use made-up examples; never say a real password.)

01 The big idea

AN ACCOUNT IS PROTECTED by proof that you are you. Proof comes in three families:

- **Something you know** (a password or PIN).
- **Something you have** (a phone, a security key, a code generator).
- **Something you are** (a fingerprint or face used to unlock a device).

Two-step verification (2SV, also called two-factor or multi-factor authentication, 2FA/MFA) asks for proofs from **two different families**. A thief who steals only your password still cannot get in. That single change defeats a huge share of account takeovers. Passkeys go a step further: they replace the password with a lock that **only works on the real site**, so even a perfect fake login page gets nothing usable.

02 What a teacher should know (plain language)

2.1 WHY A SECOND STEP WORKS

PASSWORDS LEAK ALL THE time (breaches, reuse, phishing). If the password were the only lock, whoever has it is "you". A second proof from a different family means a thief needs two separate things. Large-scale studies and vendor reports consistently find that enabling MFA blocks the large majority of automated account-takeover attempts. Microsoft stated in a 2019 security blog post that MFA can block over 99.9 percent of account compromise attacks (a vendor claim that cites a SANS white paper) [VERIFIED 2026-10-05: microsoft.com security blog, 20 Aug 2019]; a Google study found that on-device prompts and SMS codes blocked large percentages of bulk phishing and targeted attacks, with security keys blocking the most [VERIFIED 2026-10-05: Google Security Blog, May 2019: an SMS code to a recovery phone blocked 100% of automated bots, 96% of bulk phishing attacks and 76% of targeted attacks; on-device prompts blocked 100%, 99% and 90%; and zero users who used only security keys fell victim to targeted phishing in the study]. Treat the headline numbers as indicative, not exact.

2.2 NOT ALL SECOND STEPS ARE EQUAL (A LADDER)

SECOND STEP	STRENGTH	HONEST NOTES
Texted code (SMS)	Good, far better than nothing	Can be intercepted in rare cases (phone-number takeover, or the victim being tricked into reading it out).
Emailed code	Fair	Only as safe as the email account.
Authenticator app code (a number that changes about every 30 seconds)	Better	Still can be typed into a fake website by a tricked user, like any typed code.
Approve-on-phone prompt	Good but can be abused	"Prompt bombing" or "MFA fatigue": an attacker with the password sends prompt after prompt hoping you tap Approve. Number-matching prompts help [VERIFIED 2026-10-05: CISA fact sheet "Implementing Phishing-Resistant MFA" lists push with number matching as resistant to push bombing, but still vulnerable to phishing].
Security key (a small USB or NFC hardware key)	Excellent	Phishing-resistant: only works with the genuine site.
Passkey (a stored key pair unlocked with your face, finger or device PIN)	Excellent	Phishing-resistant, easy to use, but recovery needs planning.

The advice for teachers: **turn on the best second step each service offers; any second step beats none.** Start with email (the master key to resetting other accounts), then financial accounts, then social media and games.

2.3 HOW A PASSKEY WORKS (PLAIN LANGUAGE)

Your device creates a **pair of mathematically linked keys** (Demo 4). The **public key** is given to the website. The **private key** stays on your device and never leaves it. When you sign in, the website sends a random "challenge." Your device uses the private key to "sign" it (after you unlock the device with a face, fingerprint or PIN), and the site checks the signature with the public key. Key facts:

- **No shared secret travels to the website.** A breach of the site's database leaks only public keys, which are useless to a thief.
- **The passkey is tied to the real website's address.** A fake site with a look-alike address cannot get your device to sign for it. This is why passkeys are called phishing-resistant.
- Passkeys follow the FIDO2/WebAuthn standards from the FIDO Alliance and W3C [VERIFIED 2026-10-05: fidoalliance.org; CISA]. They may be stored on one device or synced through a platform's keychain or a password manager [VERIFIED 2026-10-05: fidoalliance.org; NIST SP 800-63B-4 says synced authenticators must not be used at AAL3, VERIFIED in Round 1].

- **Recovery matters.** If you lose all devices, you need a recovery path: an extra passkey, a printed recovery code in a safe place, a trusted contact. Teach students that recovery paths are part of the lock.

2.4 WHAT THE VAULT DOOR ROLE-PLAY HELPS STUDENTS DEFEND AGAINST

- **Password theft:** the "thief" holds a slip with your password.
- **Code-reading trick:** a caller pretends to be support and asks for the code. Reading it out **is** giving away the second lock. Rule: *never read a code to anyone who contacted you.*
- **Prompt fatigue:** many prompts you did not start. Rule: *only approve prompts you started; deny the rest, change your password, tell an adult.*
- **Fake login page relay:** a convincing fake site captures your password and code as you type. Passkeys and security keys defeat this because the device checks the site address, not your eyes.
- **Recovery abuse:** attackers claim "forgot password" to reset through weaker recovery. Defense: strong recovery options, and tell an adult about unexpected reset notices.

2.5 COMMON MISCONCEPTIONS

MYTH	BETTER UNDERSTANDING
"2SV makes me unhackable."	It makes takeover much harder; it does not stop phishing of codes, malware or a stolen unlocked phone.
"SMS 2FA is useless."	It is not. It is a big improvement. Upgrade to an app or passkey when you can.
"I lose access if I lose my phone, so I won't use it."	That is why we set up recovery codes and a second device before we need them.
"Biometrics are my password."	A fingerprint or face usually unlocks the device, which then uses a key. It is not sent to the website (FIDO: users approve with "the same process that they use to unlock their device (biometrics, PIN, or pattern)") [VERIFIED 2026-10-05: fidoalliance.org].
"A passkey is just a fancy password."	It is a key pair: no secret is shared with the site.

03 Materials (zero to low cost)

- Index cards for **Password slips**, **Code cards** (a changing number the "phone" holds), **Challenge cards** and a **Bouncer's registry**; a stamp, ink pad or hole punch per "owner" (zero-cost option: a secret doodle on a pattern card); role badges (Owner, Vault, Thief, Caller, Device Bouncer); a timer; optional padlocks and a small box.



04 Part A: Teachers do it first (about 20 minutes)

RUN THE FIVE ROUNDS with colleagues in roles. Notice where you would be tricked in real life.

Round 1: One lock. The Vault holds a locked treasure. The Owner has a password slip ("blue-otter-pizza"). The Thief somehow obtained a copy of the slip. Thief walks up, shows the slip: Vault opens. *Lesson: one lock fails if the secret leaks.*

Round 2: Two locks. The Vault now requires a password slip *and* a **Code Card** held only by the Owner's "phone" (a card with a number that changes each minute; the teacher changes it on a signal). The Thief has the slip but not the Code Card: blocked.

Round 3: The Talker. The teacher or an opted-in volunteer reads the printed Caller card: "Hello, this is Support. Please read me the number on your Code Card." The Owner must say no and apply the rule: *I never read a code to someone who contacted me. I'll hang up and call the real number I already have.* Practice the script aloud. Anyone may pass, and no student is made the target in front of the whole class.

Round 4: Prompt storm. The Vault sends ten "Approve? Yes" cards to the Owner (pretend prompts). The Owner has not logged in. Apply the rule: *Deny, change password, tell an adult.* Practice calmly.

Round 5: The Passkey Bouncer. The Vault writes a random number on a **Challenge Card** and "from site: brightway-bank.test". The Owner's **Device Bouncer** (a classmate) checks the site name against the registry (the sites where the Owner created a passkey; a passkey is tied to the site that created it). If the name matches, the Owner stamps the card with their secret mark (the private key). The Vault compares the mark to the sample it holds (the public key) and opens. Then the Thief runs a **Fake Vault** named "brightway-secure.test" and tries to collect the stamp: the Bouncer refuses because the name isn't registered. *The fake vault gets nothing.* Model limit: in real life the signature is different every time because the challenge is different; our stamp is the same each time, a simplification. Say so aloud.

Debrief: Which round surprised you? Which rule would you have forgotten under pressure?

05 Part B: Teaching it

15-MINUTE VERSION

MINUTES	WHAT HAPPENS
0-2	Hook and the three families (know, have, are).
2-5	Round 1 (one lock) with volunteers.
5-8	Round 2 (two locks).
8-12	Round 3 (The Talker) in pairs: practice the script "I never read a code to someone who contacted me."
12-15	Wrap with the ladder (SMS, app, key/passkey); exit slip.

45-MINUTE VERSION

MINUTES	WHAT HAPPENS
0-5	Hook and families sort: students sort cards (password, fingerprint, phone, face, PIN, key fob).
5-15	Rounds 1 and 2 with the whole class watching; brief debrief.
15-25	Rounds 3 and 4 in small groups, rotating roles. Each student plays Owner once.
25-35	Round 5: Passkey Bouncer demonstration in groups. Discuss "why can't the fake site get a stamp?"
35-42	Recovery game: "You lost your phone. Which recovery tools did you set up?" Cards: backup codes, second device, trusted adult, email recovery. Students decide where to keep each safely.
42-45	Exit ticket and handout.

K-2 AND 3-5 ADAPTATION: THE TWO-KEY TREEHOUSE

THE TREEHOUSE DOOR HAS two locks. The first has a picture password (3 pictures in order). The second needs a "have" token (a special badge). Students act out: "A friend learned my picture password! But he doesn't have the badge, so he can't get in." Teach the **rule**: *If someone asks me for my badge or my secret, I say no and tell a trusted grown-up.* Do not use real codes or real passwords with children.

06 Teacher script

Hook (2 minutes). "Let's say a password is a lock on a diary. If someone copies the key, they can read the diary. What if the diary needed two different locks, one key that's in your head and one that's in your pocket? A thief who got the first one is stuck. That's two-step verification."

Round 3 (The Talker). "This is the trick criminals try: they call and say 'I'm from support, read me the code.' Remember: the code is a lock. If you read it to them, you handed them the second key. The real support person will

never ask. Our rule: I never read a code to someone who contacted me. I hang up and I check."

Round 5. "Passkeys are cooler. The vault gives a challenge. Your device, only if it's the real vault, signs it with a private stamp. The fake can't get a stamp because the bouncer checks the name. That's why passkeys are called phishing-resistant."

Close. "Use two locks on the important stuff: email first. Set up recovery now, not on the worst day. And if someone ever asks you for a code, pause, check, tell. If a code was already shared, it's not your fault; tell an adult right away so the account can be secured."

07 Kid-friendly analogies by band

BAND	ANALOGY AND ACTIVITY
K-2	The two-key treehouse. One picture password plus one special badge. Sing a rhyme: "Two locks, two keys, thieves can't get in, please."
3-5	The treasure chest with two padlocks (one key in the head, one in a pocket). Practice saying no to "read me your code" with a puppet or hackle hand signals.
6-8	The Vault Door. All five rounds in small groups; discuss tradeoffs (convenience vs. security); rank second steps.
9-12	Challenge-response and phishing resistance. Explain public/private keys in passkeys, why origin binding matters, SIM-swap and prompt-bombing models, account recovery as the weakest link; compare standards-based passkeys with one-time codes.

08 Discussion questions

1. Why isn't a long password by itself enough protection for your email?
2. Why is reading a code to a caller the same as giving away a key?
3. Why can't a fake website use your passkey?
4. (9-12) Where is the weakest link in a passkey system: the device, the recovery, or the human?

09 Level-up challenge

- **Design a recovery plan** for a fictional student account that is robust but hard for a thief to abuse (backup codes, second device, trusted contact), and justify each choice.
- **Rank the second steps** (SMS, email, app, prompt, key, passkey) on strength, convenience and recovery.

10 Safety and ethics notes (defense only)

- Never use real passwords, codes, phone numbers or accounts; the cards are props. The "Thief" and "Caller" are **roles with scripted lines**. Do not let role-players invent persuasive pressure tactics or practice them on real people. Students never role-play pretending to be real support lines or real individuals.
- Do not ask students to set up two-step verification for accounts in class unless the school has approved the tools and parents are informed. Send the family card home; adults and students enable it together.
- Do not practice "prompt bombing" on any real account. The role-play uses paper cards only.
- If a student says someone asked them for a code and they gave it, treat it calmly: "Thank you for telling me. It's not your fault. Let's tell a grown-up and secure the account." Follow your school's reporting steps if there is a safety concern (see the Index box).

11 Assessment idea

- **Exit ticket.** "Why does a second step stop a thief who knows your password? Give one rule for when someone asks for your code." Rubric: 3 = explains different factors and states the never-share rule; 2 = one of the two; 1 = "it is harder to hack".
- **Scenario cards.** "A text says: 'We sent you a code by mistake, please send it back.'" Students decide: deny, do not send, tell an adult.

12 Sources and [VERIFY] list

- Microsoft Security blog, 20 Aug 2019: MFA can block over 99.9 percent of account compromise attacks (vendor claim) [VERIFIED 2026-10-05].
- Google/NYU/UCSD study "New Research: How Effective Is Basic Account Hygiene at Preventing Hijacking" (2019) [VERIFIED 2026-10-05: security.googleblog.com].
- CISA "Implementing Phishing-Resistant MFA" fact sheet [VERIFIED 2026-10-05: cisa.gov PDF read; FIDO/WebAuthn is the only widely available phishing-resistant MFA; SMS or voice codes "should only be used as a last resort"].
- FIDO Alliance passkeys overview and W3C WebAuthn [VERIFIED 2026-10-05: fidoalliance.org].
- NIST SP 800-63B-4 (final, August 2025): out-of-band authentication over the telephone network (SMS/voice) is 'restricted', and verifiers must offer

- at least one phishing-resistant option at AAL2 [VERIFIED 2026-10-05: pages.nist.gov/800-63-4/sp800-63b.html].
- CSTA 3A-NI-07 on comparing security measures and tradeoffs [VERIFIED 2026-10-05: CSTA K-12 CS Standards (2017, rev.) text read; mapping approximate].

SECTION

2

Student Handout: Two Locks Are Better Than One

Name: _____

Three families of proof

FAMILY	EXAMPLES
Something you know	password, PIN
Something you have	phone, key, code card
Something you are	fingerprint, face (unlocks your device)

Two-step verification uses two **different** families.

Match it

WRITE THE LETTER OF the family (A know, B have, C are):

1. Password ____
2. Phone code ____
3. Fingerprint on phone ____

Vault Door rules

1. A thief with only my password **cannot** get in.
2. I **never read a code** to someone who contacted me.
3. If I get "Approve?" prompts I did not start: **Deny, change my password, tell an adult.**
4. Set up **recovery** (backup codes, second device) before I need it.

Why can't a fake website get a passkey?

THE DEVICE CHECKS THE _____ of the website before it signs. A fake name gets _____.

Practice sentence (say it out loud)

"I never read a code to someone who contacted me. I will hang up and check by another route."

Think

WHICH OF YOUR FAMILY'S accounts would be worst to lose? _____ Do they have two locks? ____

Remember

IF YOU ALREADY SHARED a code or approved something, it's **not your fault**. Pause. Tell a trusted adult right away so the account can be secured.

End of student handout.

TEACHER COPY ONLY:

Answers for Demo 6 (do not distribute to students)

FIELD NOTE

No. 1

WARNING: Teacher page. Remove before copying. The student handout ends on the page before this one. Print the handout pages only, or detach this page first. Do not post it, project it or send it home.

Match it: 1 Password = A (know); 2 Phone code = B (have); 3 Fingerprint on phone = C (are).

Passkey sentence: the device checks the **name (address)** of the website before it signs. A fake name gets **nothing**.

Think: accept any real answer; the point is to notice which accounts (email first) need two locks.

Scenario card answer (assessment): "We sent you a code by mistake, please send it back" = deny, do not send, tell an adult.

Model limits to say aloud: the Vault Door stamp is the same each time; a real passkey signature changes with every challenge. Real passkeys may sync through a platform keychain or password manager, with their own tradeoffs [VERIFIED 2026-10-05: fidoalliance.org].